CNOVI PROGRAMACIÓN WAP

Reporte laboratorio #8: File path traversal Traversal sequences blocked with absolute path bypass



Lizeth Infante Martínez

Reporte de Laboratorio: File path traversal Traversal sequences blocked with absolute path bypass

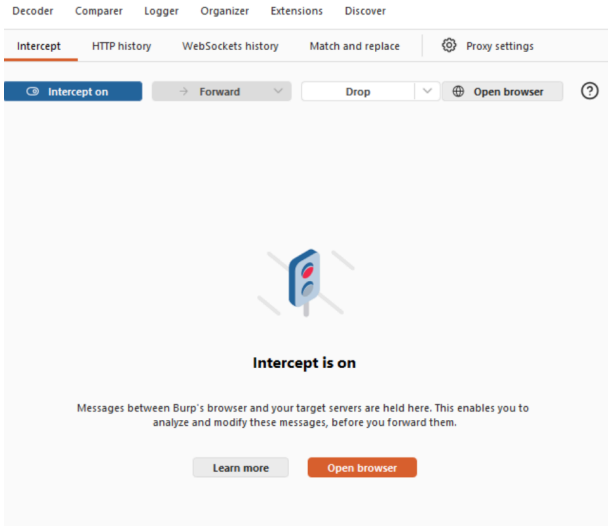
1. Objetivo

Demostrar la vulnerabilidad de salto de directorio mediante ruta absoluta (Absolute Path Bypass) cuando las secuencias de salto (../) están bloqueadas en una aplicación web. Se utiliza Burp Suite para interceptar, modificar y reenviar peticiones con el fin de acceder al archivo restringido del servidor (/etc/passwd).

2. Metodología y Pasos de Resolución

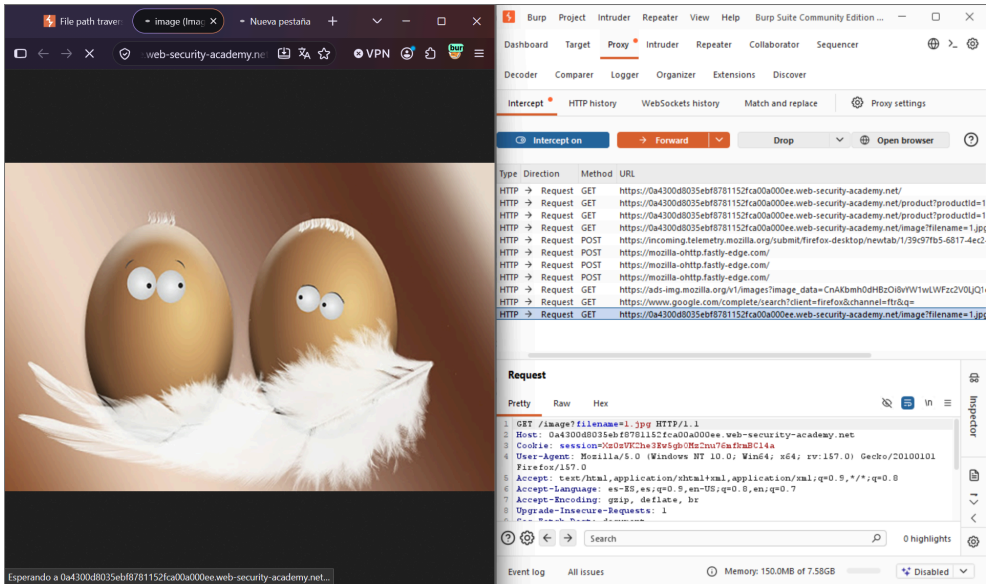
Paso 1: Configurar la intercepción en Burp Suite

- Ve a la pestaña Proxy en Burp Suite y asegúrate de que el botón indique Intercept on (Interceptación activada).



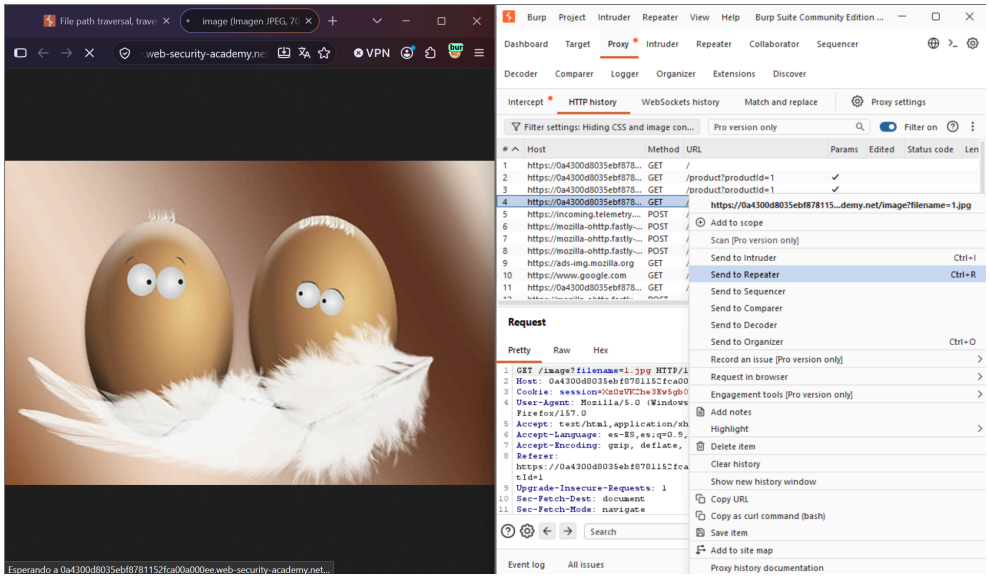
Paso 2: Generar la petición de una imagen de producto

- Dirígete a la ventana del navegador integrada en Burp o a tu navegador configurado con el proxy.
- Haz clic en cualquiera de los productos de la tienda (por ejemplo, "Hitch A Lift") para ver los detalles o cargar una imagen y generar la solicitud HTTP correspondiente.



Paso 3: Interceptar, modificar la solicitud y usar el Repeater

- La petición se pausará en Burp Suite en la pestaña Proxy > Intercept. Verás una solicitud HTTP que incluye un parámetro llamado filename=.
- En la lista de HTTP history, localiza la petición correspondiente (GET /image?filename=1.jpg) y haz clic derecho para seleccionar Send to Repeater (o presiona Ctrl + R).

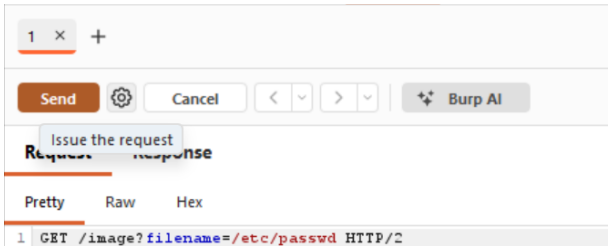


- Abre la pestaña Repeater en el menú superior de Burp Suite.
- En el panel de la petición HTTP, ubica la primera línea y modifica el parámetro filename utilizando la ruta absoluta para evadir el bloqueo de secuencias relativas:

GET /image?filename=/etc/passwd HTTP/2



- Haz clic en el botón Send en la esquina superior izquierda de la pestaña Repeater para emitir la solicitud.



3. Verificación y Resultados

- **Panel de Respuesta (Repeater):** Al enviar la petición modificada con la ruta absoluta, revisa el panel de respuesta (Response). Se observa el código de estado 200 OK y el contenido completo del archivo /etc/passwd (líneas de texto que comienzan con usuarios como root:x:0:0..., daemon:x:1:1..., etc.), lo que confirma que la vulnerabilidad ha sido explotada con éxito.
- **Navegador:** Al comprobar el estado en el navegador del laboratorio, se visualiza la notificación de que el reto ha sido completado satisfactoriamente (Congratulations, you solved the lab!).

